

Penetration Test — Avaliação de Segurança

Relatório Executivo

CALYPSO PAY

Gateway de Pagamentos e Emissor de Cartão de Crédito

23 de agosto de 2026

Desafio Técnico — Processo Seletivo Analista de Segurança Pleno
Sea Tecnologia

1. Objetivo

O objetivo deste trabalho foi executar um Penetration Test (PenTest) sobre a aplicação Calypso Pay, um gateway de pagamentos e emissor de cartão de crédito, no âmbito do desafio técnico da etapa seletiva para a posição de Analista de Segurança Pleno na Sea Tecnologia.

A avaliação buscou mapear os principais riscos de segurança presentes na aplicação, identificando vulnerabilidades exploráveis em um cenário real de ataque, com foco em autenticação, autorização, validação de entrada e lógica de negócio — pilares centrais de uma aplicação financeira.

2. Metodologia

A metodologia adotada para a realização dos testes presentes neste relatório foi baseada no PTES — Penetration Testing Execution Standard, balizada e documentada com base em referências como o OWASP Top 10 (2021), OWASP API Security Top 10 (2023), Common Weakness Enumeration (CWE) e MITRE ATT&CK®, framework utilizado para catalogar as táticas e técnicas empregadas durante os testes.

De acordo com as regras de engajamento definidas no desafio, a abordagem utilizada foi Black-Box: nenhuma documentação formal, credencial privilegiada ou código-fonte foi disponibilizado previamente à equipe de teste.

As seguintes etapas foram realizadas durante a avaliação:

Discovering	Scanning	Enumeration	Gaining Access
Identificação do ambiente Docker (containers, portas, tecnologias) e mapeamento inicial da aplicação (Rails/Nginx/Postgres).	Reconhecimento de rede (nmap) e enumeração ativa de rotas/diretórios (ffuf) não referenciadas na interface.	Mapeamento de fluxos de autenticação, autorização, validação de entrada e lógica de negócio via proxy de interceptação (Burp Suite).	Exploração confirmada das vulnerabilidades identificadas, com evidências de reprodutibilidade e avaliação de impacto real.

Ferramentas utilizadas: Burp Suite Community Edition (proxy de interceptação e Repeater), ffuf (enumeração de rotas), nmap (reconhecimento de portas), DevTools do navegador, webhook.site (validação de exfiltração via XSS) e requisições manuais via curl.

3. Critério para Classificação dos Riscos

As vulnerabilidades mapeadas foram classificadas e priorizadas de acordo com o Common Vulnerability Scoring System (CVSS) e a metodologia OWASP Risk Rating, considerando o vetor de acesso, a complexidade de exploração, a necessidade de autenticação e o impacto na confidencialidade, integridade e disponibilidade dos dados.

Classificação	Critério
Crítico	Falhas que possibilitam controle total ou parcial da aplicação, comprometimento de dados de terceiros em massa, ou escalonamento de privilégio sem autenticação prévia.
Alto	Falhas que desencadeiam ataques posteriores, possibilitando vazamento de dados, exposição de informações sensíveis ou fraude direta contra a lógica de negócio.

Médio	Falhas que expõem dados sobre a arquitetura e tecnologia do sistema, servindo como vetor de apoio para explorações futuras.
Baixo	Falhas que permitem reconhecimento e enumeração de componentes, sem impacto direto isolado.

4. Escopo

Abaixo, o ativo avaliado:

Modalidade	Tipo de Pentest	Alvo
Black-Box	WEB / API	Calypso Pay — http://localhost (ambiente Docker Compose local, isolado, fornecido pela Sea Tecnologia)

Regras de engajamento: escopo restrito à aplicação Calypso Pay; permitida enumeração, injeção, manipulação de parâmetros, análise de tokens e automação; vedados ataques de negação de serviço, engenharia social e inspeção do container por dentro (shell escape). Dados de teste utilizados foram exclusivamente sintéticos.

5. Sumário Executivo

Durante o trabalho foram identificadas e exploradas 7 vulnerabilidades, sendo 3 classificadas como Críticas, 3 como Altas e 1 como Média. Adicionalmente, 6 pontos positivos foram identificados, refletindo controles de segurança corretamente implementados. Abaixo, o resumo consolidado dos findings:

5.1 Findings: Aplicação Web

ID	Vulnerabilidade	Recomendação	Risco
W.1	Mass Assignment em Cadastro Público (Escalonamento de Privilégio)	Aplicar Strong Parameters explícitos no controller de cadastro, permitindo apenas os campos esperados (nome, e-mail, senha, CPF). Nunca aceitar atribuição em massa de atributos sensíveis como role/tipo de conta a partir de entrada do usuário não autenticado.	Crítico
W.2	Broken Access Control em Área Administrativa	Implementar verificação de autorização (role-based access control) em toda ação de controllers sob o namespace /admin, rejeitando qualquer requisição de usuário sem privilégio de administrador com HTTP 403. Adicionar testes automatizados de autorização.	Crítico
W.3	IDOR — Exposição de Dados Completos de Cartão de Terceiros	Validar no controller que o cartão solicitado (credit_card.user_id)	Crítico

		pertence ao usuário autenticado antes de renderizar a resposta, retornando 404 caso contrário. Mascarar número completo (PAN) e CVV em qualquer exibição, exibindo apenas os últimos 4 dígitos.	
W.4	CORS Misconfiguration com Credenciais Habilitadas	Restringir o header Access-Control-Allow-Origin a uma allowlist fixa de domínios confiáveis, nunca refletindo o header Origin recebido dinamicamente quando Access-Control-Allow-Credentials estiver habilitado.	Alto
W.5	Falha de Regra de Negócio na Emissão de Cartão de Crédito	Implementar validação server-side que condicione a aprovação do tier Prime Ogígia à renda declarada mínima (R\$ 8.000), e defina uma política explícita de limite de cartões ativos por usuário.	Alto
W.6	Stack Trace Disclosure (Verbose Error Messages)	Configurar o ambiente para exibir páginas de erro genéricas ao usuário final (config.consider_all_requests_local = false em produção), registrando o stack trace completo apenas em logs internos.	Médio
W.7	Cross-Site Scripting (XSS) Refletido	Garantir que toda saída dinâmica renderizada em views utilize os mecanismos de auto-escape do framework (evitar raw()/html_safe() em dados de entrada do usuário). Implementar Content-Security-Policy como camada de defesa adicional.	Alto

Tabela 5.1.1 — Tabela consolidada dos findings identificados na aplicação Calypso Pay

5.2 Findings: Pontos Positivos

ID	Alvo	Descrição
P.1	/signup, /login, /credit_cards	Proteção CSRF (authenticity_token) presente e validada em todos os formulários testados, seguindo o padrão do Rails.
P.2	Cookie _calypso_session	Cookie de sessão configurado com atributo HttpOnly, impedindo leitura via document.cookie mesmo em cenário de XSS confirmado (W.7), mitigando o roubo direto de sessão.
P.3	/login	Ausência de SQL Injection: testes com payloads clássicos (' OR '1'='1, comentário SQL, aspas simples) via manipulação direta de requisição confirmaram uso de queries

		parametrizadas (ActiveRecord).
P.4	/signup (campo nome)	Escape de saída HTML corretamente aplicado no campo "nome" do cadastro, testado com payload de script e confirmado como renderizado em texto literal, sem execução.
P.5	/statement, /statement/export	Escopo de dados corretamente restrito à sessão do usuário autenticado na funcionalidade de extrato e exportação CSV — testes de manipulação de parâmetros (user_id) não retornaram dados de terceiros.
P.6	Resgate de cupom promocional	Validação de código de cupom contra lista fixa no backend, rejeitando entrada de texto livre e prevenindo injeção de conteúdo malicioso por esse vetor.

Tabela 5.2.1 — Tabela consolidada dos pontos positivos identificados

6. Indicadores

6.1 OWASP Risk Rating Calculator

Aplicando a metodologia OWASP Risk Rating ao cenário agregado de maior impacto identificado (escalonamento de privilégio via cadastro público seguido de acesso irrestrito a dados de cartão de terceiros), obtém-se:

Fator (Threat Agent)	Valor	Fator (Impact)	Valor
Skill Level	3 — Some technical skills	Loss of Confidentiality	9 — Extensive critical data disclosed
Motive	9 — High reward	Loss of Integrity	9 — Extensive data corruption possible
Opportunity	9 — No access/resources required	Loss of Availability	1 — Minimal
Size	9 — Anonymous Internet users	Loss of Accountability	7 — Possibly traceable
Ease of Discovery	9 — Automated tools available	Financial Damage	7 — Significant effect on profit
Ease of Exploit	9 — Automated tools available	Reputation Damage	8 — Brand damage
Awareness	7 — Public knowledge (OWASP Top 10)	Non-Compliance	7 — High profile violation (PCI-DSS/LGPD)
Intrusion Detection	8 — Not logged / sem monitoramento evidente	Privacy Violation	7 — Hundreds of people (PAN/CVV/CPF)

Likelihood Score	Impact Score
7,875 — HIGH	6,875 — HIGH

RISCO GERAL: CRÍTICO

Figura 6.1.1 — OWASP Risk Rating Calculator (cenário de maior impacto)

6.2 OWASP Top 10 — Web Application (2021)

Mapeamento da aplicação em conformidade (ou não) com as categorias do OWASP Top 10:

ID	Descrição	Status	Ref	Justificativa
A01	Broken Access Control	Non-Compliance	W.1, W.2, W.3	Mass assignment permite escalonamento a admin; painel administrativo e dados de cartão de terceiros acessíveis sem verificação de propriedade/role.
A02	Cryptographic Failures	Compliance	—	Cookie de sessão criptografado/assinado (padrão Rails) e com atributo HttpOnly corretamente configurado.
A03	Injection	Non-Compliance	W.7	Cross-Site Scripting refletido confirmado no parâmetro de busca do extrato. SQL Injection testado e não explorável.
A04	Insecure Design	Non-Compliance	W.5	Ausência de validação server-side de regras de negócio na aprovação de crédito (tier vs. renda declarada).
A05	Security Misconfiguration	Non-Compliance	W.4, W.6	CORS reflete Origin arbitrária com credenciais habilitadas; mensagens de erro expõem stack trace completo.
A06	Vulnerable and Outdated Components	Compliance	—	Nenhuma versão de framework/biblioteca desatualizada ou vulnerável foi identificada (Rails 8.1.3.1 / Ruby 3.4.0).
A07	Identification and Authentication Failures	Compliance	—	Proteção CSRF presente; login não vulnerável a SQL Injection nem bypass de autenticação nos testes realizados.
A08	Software and Data Integrity Failures	Compliance	—	Nenhum ponto específico identificado relacionado a falhas de integridade de software/deserialização.
A09	Security Logging	Non-Compliance	W.6	Exposição de stack

	and Monitoring Failures			trace ao usuário final sugere ausência de tratamento de erro e monitoramento adequados em produção.
A10	Server-Side Request Forgery (SSRF)	Compliance	—	Não foram identificados endpoints que realizem requisições a URLs fornecidas pelo usuário.

Tabela 6.2.1 — Testes realizados com base no OWASP Top 10

6.3 MITRE ATT&CK

O MITRE ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge) documenta o comportamento de atacantes com base em observações reais, organizando as ações ofensivas em táticas e técnicas. Abaixo, o mapeamento das técnicas utilizadas ou observadas durante a exploração das vulnerabilidades do Calypso Pay:

Vulnerabilidade	Tática	MITRE ID	Técnica	Risco	Mitigação
W.1	Persistence / Privilege Escalation	T1136.001	Create Account: Local Account	Crítico	Strong Parameters
W.1	Defense Evasion / Persistence	T1078	Valid Accounts	Crítico	Revisão de contas privilegiadas
W.2	Discovery	T1595	Active Scanning	Crítico	Autorização por rota
W.2	Collection	T1213	Data from Information Repositories	Crítico	RBAC em /admin/*
W.3	Discovery	T1595	Active Scanning	Crítico	Validação de propriedade
W.3	Collection	T1213	Data from Information Repositories	Crítico	Mascaramento de PAN/CVV
W.4	—	N/A	Sem técnica MITRE precisa (ver nota metodológica)	Alto	Allowlist de Origin
W.5	—	N/A	Sem técnica MITRE precisa (ver nota metodológica)	Alto	Validação server-side
W.6	Reconnaissance	T1592.002	Gather Victim Host Info: Software	Médio	Erros genéricos em produção
W.7	Initial Access / Execution	T1659	Content Injection	Alto	Auto-escape + CSP
W.7	Credential Access	T1539	Steal Web Session Cookie	Alto	HttpOnly (já mitigado)

Tabela 6.3.1 — Táticas e técnicas utilizadas com base no MITRE ATT&CK

Nota metodológica: para os achados W.4 (CORS Misconfiguration) e W.5 (falha de regra de negócio), não foi identificada uma técnica do MITRE ATT&CK que represente com precisão a natureza da falha — trata-se, respectivamente, de uma configuração insegura de infraestrutura web e de uma ausência de validação de regra de negócio, sem uma técnica de adversário específica e amplamente aceita no framework para esses cenários. A classificação de risco desses dois achados apoia-se primariamente em CWE e OWASP Top 10, evitando um mapeamento MITRE forçado apenas para preencher a tabela.

7. Conclusão

De acordo com as análises realizadas, entende-se que o risco de segurança no escopo avaliado da Calypso Pay é Crítico. Ao contrário de falhas isoladas de baixo impacto, o encadeamento observado — cadastro público manipulável para obtenção de privilégio administrativo, seguido de acesso irrestrito a um painel administrativo e a dados completos de cartão de crédito de terceiros (PAN e CVV) — representa comprometimento total da confidencialidade dos dados financeiros da base de usuários, sem exigir qualquer credencial prévia.

Alguns pontos merecem atenção e priorização imediata na correção:

- A combinação de Mass Assignment (W.1) com a ausência de controle de acesso no painel administrativo (W.2) permite que qualquer visitante não autenticado obtenha controle administrativo completo da plataforma através de uma única requisição HTTP manipulada.
- O IDOR em `/credit_cards/:id` (W.3) expõe número completo (PAN) e código de segurança (CVV) de cartões de crédito de qualquer usuário da base a partir de uma conta comum, configurando risco direto de fraude financeira e não conformidade com padrões PCI-DSS.
- A ausência de validação de regra de negócio na emissão de cartões (W.5) permite a aprovação de produtos premium (Prime Ogígia) para clientes que não atendem ao critério mínimo de renda, além de emissão ilimitada de cartões por conta.
- A CORS Misconfiguration (W.4) foi confirmada pela reflexão arbitrária do header Origin combinada com `Access-Control-Allow-Credentials: true` — condição objetivamente insegura que amplia a superfície de ataque ao viabilizar requisições cross-origin autenticadas; a exploração completa a partir de uma origem externa contra uma vítima real não foi necessária para confirmar a falha de configuração. O XSS Refletido (W.7), por sua vez, teve sua execução efetivamente confirmada via prova de conceito com exfiltração real de requisição para servidor externo (`webhook.site`).

Em conjunto, essas falhas demonstram deficiências estruturais de controle de acesso, validação de entrada server-side e gestão de exposição de erros, que — se replicadas em ambiente de produção — exporiam a Calypso Pay a fraude financeira direta, vazamento massivo de dados de cartão de terceiros e comprometimento total da confidencialidade e integridade da base de usuários.

Cabe destacar que, mesmo diante desse cenário, foram identificados controles corretamente implementados (Seção 5.2) — como a proteção contra SQL Injection, o correto escape de saída no campo nome, e o atributo `HttpOnly` no cookie de sessão — que demonstram pontos de acerto na base do framework utilizado (Rails) e evidenciam que as falhas encontradas são majoritariamente de lógica de aplicação, não de infraestrutura de base.

Ressalta-se que nossas atividades não esgotam nem encerram todas as possibilidades de identificação de riscos e vulnerabilidades, representando o melhor esforço dentro do prazo e abrangência definidos para este desafio.

8. Próximos Passos

Recomenda-se como próximos passos:

- Corrigir prioritariamente as vulnerabilidades classificadas como Críticas (W.1, W.2, W.3), dado o potencial de comprometimento total de dados financeiros de terceiros sem necessidade de autenticação prévia.
- Implementar um processo de revisão de segurança (code review / SAST) focado em Strong Parameters, autorização por objeto (object-level authorization) e validação de regras de negócio server-side antes de novos releases.
- Adotar testes automatizados de autorização (ex.: um usuário nunca deve conseguir acessar recurso de outro usuário trocando um ID) como parte da esteira de CI/CD.
- Configurar tratamento de erro apropriado para ambiente de produção, eliminando a exposição de stack traces e detalhes de infraestrutura ao usuário final.
- Reavaliar o ambiente após a implementação das correções, validando especificamente os findings críticos e altos deste relatório.